



**BLUE TEAM
LABS ONLINE**
Powered by Security Blue Team

RESOLUCIÓN DE LABORATORIO

Lab: Phishing Analysis 2 (BTLO)

Análisis forense de una campaña de phishing que suplanta a Amazon, extrayendo artefactos desde el correo: remitente falsificado, URLs maliciosas ofuscadas y contenido codificado en Base64.

Escenario:

Put your phishing analysis skills to the test by triaging and collecting information about a recent phishing campaign.

Herramientas utilizadas:

- Thunderbird
- Cyberchef
- microlink.io

Resumen:

El presente caso analiza una campaña de phishing que representa la fase de acceso inicial de un potencial ataque, empleando como vehículo un correo electrónico fraudulento. El atacante suplantó la identidad de Amazon mediante spoofing, utilizando la dirección amazon@zyevantoby.cn con el nombre de pantalla Amazn, dirigido a la víctima saintington73@outlook.com. El mensaje, enviado el 14 de julio de 2021 a las 01:40 horas (UTC+0900, zona horaria correspondiente a Japón o Corea del Sur), empleó ingeniería social por urgencia simulando un bloqueo de cuenta. El contenido del correo se encontraba codificado en Base64, ocultando tanto el cuerpo del mensaje como una plantilla HTML que clonaba la identidad visual de Amazon. Dentro de esta estructura se identificaron URLs maliciosas redirigidas por Microsoft Safe Links, siendo el enlace original <https://amaozn.zzyuchengzhika.cn>, dominio de hosting chino que suplanta el nombre de Amazon, y un segundo enlace que redirige inesperadamente al perfil de Facebook amir.boyka.7. No se evidencia persistencia dado que el caso constituye únicamente la fase inicial del ataque. Respecto a la infraestructura C2, el dominio .cn y el huso horario asiático son indicadores sugestivos, aunque insuficientes para confirmarla con certeza.

P1: What is the sending email address?

R: amazon@zyevantoby.cn

Se utilizó Thunderbird para analizar e inspeccionar el código fuente del correo (headers), donde se identificó que la dirección del remitente real es amazon@zyevantoby.cn. Además, esta dirección está asociada al nombre 'Amazn' lo que confirma un ataque de phishing mediante suplantación de identidad (spoofing) de la empresa Amazon.

```
From: Amazn <amazon@zyevantoby.cn>  
To: saintington73 <saintington73@outlook.com>
```

P2: What is the recipient email address?

R: saintington73@outlook.com

Se identificó el destinatario con la dirección de email 'saintington73@outlook.com' asociado al nombre 'saintington73'.

```
From: Amazn <amazon@zyevantoby.cn>  
To: saintington73 <saintington73@outlook.com>
```

P3: What is the subject line of the email?

R: Your Account has been locked

El campo 'Subject' contiene la línea de asunto Your Account has been locked. En el cuerpo del correo se argumentan consecuencias negativas inmediatas si el usuario no interactúa con el enlace provisto. El vector de ataque se clasifica como phishing basado en ingeniería social por urgencia.

```
Subject: Your Account has been locked  
Date: Wed, 14 Jul 2021 01:40:33 +0000
```

P4: What company is the attacker trying to imitate?

R: Amazon

Como se detalló previamente, el atacante empleó una técnica de suplantación de identidad (spoofing), utilizando el nombre de pantalla manipulado 'Amazn' para simular comunicaciones legítimas de la empresa Amazon.

From: **Amzn** <amazon@zyevantoby.cn>
To: saintington72 <saintington72@ev...

P5: What is the date and time the email was sent? (As copied from a text editor)

R: Wed, 14 Jul 2021 01:40:32 +0900

La hora y fecha del envío del email malicioso se detalla en el encabezado 'Date'. Cabe recalcar que el indicador '+0900' representa el desplazamiento de la zona horaria respecto al UTC, este indicador representa la hora local de regiones como Japón o Corea del Sur, lo que evidencia el uso de servidores o infraestructura configurados en esa región asiática.

Date: Wed, 14 Jul 2021 01:40:32 +0900

P6: What is the URL of the main call-to-action button?

R:

<https://emea01.safelinks.protection.outlook.com/?url=https%3A%2F%2Famazon.zzyuchengzhika.cn%2F%3Fmailtoken%3Dsaintington73%40outlook.com&data=04%7C01%7C%7C70072381ba6e49d1d12d08d94632811e%7C84df9e7fe9f640afb435aaaaaaaaaaaa%7C1%7C0%7C637618004988892053%7CUnknown%7CTWFpbGZsb3d8eyJWljiMC4wLjAwMDAiLCJQIjoiV2luMzliLCJBTiI6I k1haWwiLCJXVCi6Mn0%3D%7C1000&sdata=oPvTW08ASiViZTLfMECswvDvguT6ODYKPQZNK3203m0%3D&reserved=0>

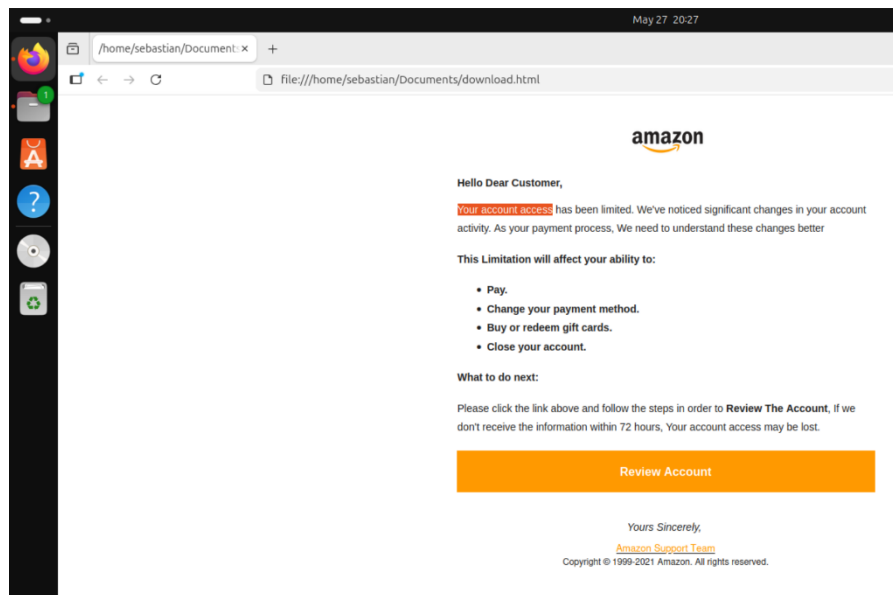
Al inspeccionar el cuerpo del código fuente del correo electrónico, se identificaron bloques de texto codificados en formato Base64.

[illegible]

PCFET0NUwVBFIEhUTUw+PGh0bWw+PGh1YWQ+CjxtZXRhIGh0dHAtZXF1aXY9IkNvbRlbnQtVHlwZSIgY29udGVudD0idGV4dC9odG1s0yBjaGZyc2V0PXBvXi04Ij48bWV0YSBuYW1lPSJHRU5FUkFUT1IiIGNvbRlbnQ=

[illegible]

El archivo HTML extraído almacena la estructura de diseño y los elementos visuales de la plantilla utilizada por la amenaza. Esta interfaz fue clonada deliberadamente por el atacante para replicar de manera idéntica la identidad gráfica y el formato de las comunicaciones oficiales de la empresa Amazon, potenciando así el engaño mediante ingeniería social.



Dentro de los atributos de esta estructura HTML, específicamente en la etiqueta de anclaje asociada al botón ‘Review Account’, se localizó la dirección URL de redirección en el atributo href. Cabe señalar que el enlace original del atacante (<https://zzyuchengzhika.cn>) fue reescrito de manera automática por la pasarela de seguridad Microsoft Safe Links del destinatario. Este mecanismo perimetral envuelve la URL maliciosa para interceptar el tráfico en tiempo de clic, analizar la reputación del sitio web de destino en tiempo real y bloquear el acceso en caso de confirmar actividades fraudulentas.

```

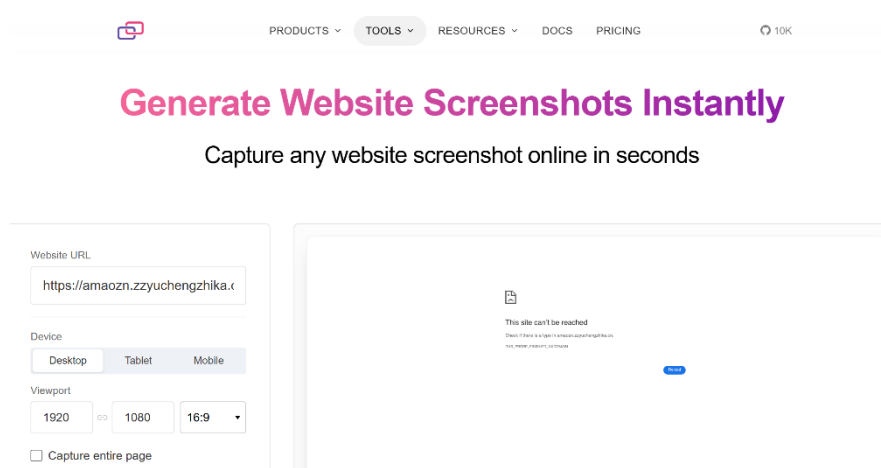
557 <TD align="center" class="mcnButtonContent" valign="middle"
558 style="padding: 20px; font-family: Arial; font-size: 10px;"><A
559 title="Review Account" class="mcnButton" style="text-align: center; color: rgb(255, 255, 255); line-height: 100%; letter-spacing: normal; font-f
560 href="https://emea01.safelinks.protection.outlook.com/?url=https%3A%2F%2Famazon.zyuzhenqihika.com%2F%3Fmailtoken%3D%40outlook.com%
561 Account/></TD></TR></TBODY></TABLE></TD></TR></TBODY></TABLE>
562 <TABLE width="100%" class="mcnTextBlock" style="min-width: 100%;
563 cellpadding="0" cellspacing="0" padding="0">
564 <TBODY class="mcnTextBlockOuter">

```

P7: Look at the URL using URL2PNG. What is the first sentence (heading) displayed on this site? (regardless of whether you think the site is malicious or not)

R: This site can't be reached

Se empleó la herramienta alternativa Microlink.io para realizar el renderizado dinámico de la URL. La captura de pantalla obtenida confirmó que el dominio malicioso se encuentra inactivo (*offline*), imposibilitando la carga del sitio web en tiempo real debido a la inexistencia de su infraestructura actual.



P8: When looking at the main body content in a text editor, what encoding scheme is being used?

R: base64

El análisis del cuerpo principal del correo electrónico mediante un editor de texto reveló que el contenido del mensaje y su estructura HTML se encuentran transferidos bajo el esquema de codificación Base64. Esto se evidencia en los encabezados de transferencia de contenido (Content-Transfer-Encoding: base64) presentes en el código fuente.

```
-----= NextPart_000_0232_018D8931.1E363E20
Content-Type: text/plain;
    charset="utf-8"
Content-Transfer-Encoding: base64

ICAgICAgICAgICAgICAgICAgICAgICAgICAgIcA0KICAgIA0KSGVsbG8gRGVhciBDDXN0b2llciwNCgOK
Ww91ciBhZ7LPsm91bnQyYWNjZXNzIGhhcyBlZWUwIGxpbWl0ZWQuIFd1J3Z1IG5vdGljZWQgc2ln
bmImakWhbnQyY2hhbmdlcyBpb1B5b3VyIGHPss-yb3VudCBhY3Rpdml0eS4gOXMgeW91ciBwYXlt
ZW50IHByb2Nlc3MsIFdlIG51ZWQgdG8gdW5kZXZjdGFuZCUB0agVzZSBjaGUFvZ2VzIGJldHRlcgOK
DqUuaGIzExppbwLIXYRpbb24gd21sbCBhZmZlY3Qgew91ciBhYmIsaXR5IHRvoQgOkZfheS5DaGFu
Z2UGew91ciBwYXltZW50IG1ldGhwZC5CdXkgb3JtcmVkJZwVtIGdpZnQoY2FyZHMuQ2xcvc2UGew91
ciBhZ7LPsm91bnQybQUpXaG9rIHhvIGRhVG5leHQ6DQONClBsZWfzZSBjbGljayB0agUGubGluaybh
Y992ZSSBhmZmc29sgBg91HROzSBzdGWccyBpb1BvcmlRclciB0byBSZXpzXCgwGH1IEFjY291bnQ5
IElmIHdlTGRvbidi0TH1JLY2VpdmdUgdGhlIG1uZm9ybWFW0aw9uIHdpdGhpbiA3MiBob3VycywGww91
ciBhZ7LPsm91bnQygYc+yz7JlczMgbWF5IGJ1IGxvc3QuDQONCG0KICAgICAgICAgICAgICAgICAg
ICAgICAgICAgICAgICAgICAgICAgICAgICAgIcA0KDQNCG0KDQONCG0KDQONCG0KDQONCljldmllyBBY2Nwdw50
DQONCG0KWmw91cnMguU2luY2VyZWxzLCANCg0KQWIhem9uIFN1chBvcncQGVhbObQ0KQ29weXJpZ2h0
IMkpIdESOTktMjAyMSBBbfW6f24uIEFsbCBYaWodHMgcmVZZXZ1ZWQwDQONCG0KICAgICAgICAg
ICAgICAgICAgICAgICAgICAgICAgICAgICAgICAgICAgIcA0KICAgICAgICAgICAgICAgICAgICAG0KDQONCG0KDQogDQo=

-----= NextPart_000_0232_018D8931.1E363E20
Content-Type: text/html;
    charset="utf-8"
Content-Transfer-Encoding: base64

PCFET0NUWVFIEhUTUw+Pg0hbw+wPg0hYWQ+CjxtZXRXIRGhdHAatXF1axY9IkNVbnRlbnQtVHlwZSw
```

P9: What is the URL used to retrieve the company's logo in the email?

R: <https://images.squarespace-cdn.com/content/52e2b6d3e4b06446e8bf13ed/1500584238342-0X2L298XVSKF8AO6I3SV/amazon-logo?format=750w&content-type=image%2Fpng>

Al inspeccionar las etiquetas de imagen () dentro de la estructura HTML del correo, se localizó la URL utilizada para renderizar el logotipo corporativo. Cabe destacar que el atacante cargó el recurso desde un servidor externo ajeno a la infraestructura de Amazon (images.squarespace-cdn.com), lo cual representa un indicador de compromiso (IoC) clave en la detección de contenido suplantado.

```
}</STYLE>
<BR>&nbsp;
<TABLE width="600" align="center" style="width: 600px;" border="0" cellpadding="0">
  <TBODY>
    <TR>
      <TD width="600" align="center" valign="top" style="width: 600px;">&nbsp;<IMG width="749" height="67" style="width: 100px;" alt="" src="https://images.squarespace-cdn.com/content/52e2b6d3e4b06446e8bf13ed/1500584238342-0X2L298XVSKF8AO6I3SV/amazon-logo?format=750w&content-type=image%2Fpng" border="0" hspace="0">
      <TABLE width="100%" class="templateContainer" border="0" cellpadding="0">
        <TBODY>
```

P10: For some unknown reason one of the URLs contains a Facebook profile URL. What is the username (not necessarily the display name) of this account, based on the URL?

R: amir.boyka.7

Dentro del contenido del correo electrónico, específicamente en la línea de texto asociada a 'Amazon Support Team', se identificó un hipervínculo manipulado. Al igual que se observó en el análisis del botón 'Review Account', la pasarela de seguridad Microsoft Safe Links interceptó este enlace reescribiendo la dirección en el atributo href de forma automatizada. Al inspeccionar el atributo originalSrc en el código HTML, se logró recuperar el enlace original del atacante, el cual redirige de manera inusual hacia una red social externa, revelando un perfil de Facebook con el nombre de usuario amir.boyka.7.

```
Sincerely,&nbsp;</EM></SPAN></SPAN><BR></P>
<DIV style="text-align: center;"><A href="https://emea01.safelinks.protection.outlook.com/?url=https%3A%2F%2Fwww.facebook.com%2Famir.boyka.7&data=04%7C01%7C7C70072381ba6e49d1d12408d94632811ek7C84df9e7fe9f640afb435aaaaaaaaaaaa%7C1%7C0%7C637618004988802053%7CUnknown%7CTWfpbGZsb3d8eyJmIjoicM4wIjAwMDAiLCJ0Ijoiv2luWzIiLCJBTiI6IkhkhwilCjVCI6Wn0%3D%7C1000&data=KV%3A%28G1%28F03v3ALNWowA1PrenHiT3aT%2Fivb5y1KxkAk%3D&reserved=0" originalSrc="https://www.facebook.com/amir.boyka.7" shash="GensOMRq15Vqvbx8htI2HuCojK10wg7AD9+j3lsp1MJ8kb6EbXKYUYje6INSTtWQ4xNGTfa9JLrYG51E0Azr3pMKAdzbJv1i+X09meWM6uWYdf1GPgi0vTMLrYMSG4WlnQk+KI7F1gVLC5jEXJj6gDuMfnhlyhET3o1HttypI=" target="" blank"><SPAN style="font-size: 13px;"><SPAN style="font-family: helvetica neue,helvetica,arial,verdana,sans-serif;"><SPAN style="color: rgb(255, 153, 0);">Amazon Support Team</SPAN></SPAN></SPAN></A><SPAN style="font-size: 12px;"><SPAN
```